Cybersecurity Lab Write-Up: TryHackMe Room Analysis

Executive Overview

The provided source document (pages 1-5) contains technical evidence of a cybersecurity lab write-up for a TryHackMe room. The document details the analysis of a binary file named `Compiled-1688545393558.Compiled` (source PDF, page 1). The evidence includes terminal commands, string extraction, symbol table analysis, and Ghidra decompiler output. The report strictly documents the observed content without inventing findings. Uncertainty is inherent: the source material does not provide explicit context for the lab's purpose, but the evidence indicates a CTF challenge involving password authentication.

Lab Overview

The source document describes a TryHackMe room (source PDF, page 1) where a binary file was analyzed. The target environment is a Linux system (indicated by the Kali Linux terminal in source PDF, page 1). The lab objective is to reverse engineer the binary to find a password that allows access. The binary is a compiled executable that prompts for a password and checks it against a specific string. The environment includes standard Linux binaries and tools (e.g., `strings`, `chmod`, Ghidra), with no network components or external systems referenced.

Reconnaissance

Reconnaissance was performed by extracting strings from the binary (source PDF, page 1). The `strings` command output (source PDF, page 1) revealed critical strings including `Password:`, `DoYouEven%sCTF`, and `Correct!`. This step identified the password prompt and the expected string format. Additionally, the symbol table (source PDF, pages 2-3) was analyzed to understand the binary's structure and dependencies. The strings section (source PDF, page 1) confirmed the presence of standard C library functions (`__libc_start_main`, `fwrite`, `printf`) and GLIBC versions (`GLIBC_2.7`, `GLIBC_2.34`), indicating a typical Linux executable.

Enumeration

Enumeration of the binary's symbols (source PDF, pages 2-3) revealed key functions and sections. The symbol table included program symbols such as `main`, `__isoc99_scanf`, and `fwrite`, as well as ELF section headers like `.text`, `.rodata`, and `.symtab`. The Ghidra decompiler output (source PDF, page 4) provided a detailed view of the `main` function, showing the password check logic: it reads input via `__isoc99_scanf` and compares it to the string `DoYouEven%sCTF`. The symbol table also showed critical entries like `_init` and `__dso_handle`, which were referenced in the password comparison logic.

Vulnerability Analysis

The binary contains a vulnerability in its password check logic. The `main` function (source PDF, page 4) uses `strcmp` to compare the input string to a fixed string. The string `DoYouEven%sCTF` is used as a template, but the actual check is for the prefix `DoYouEven` followed by the string `_init` (source PDF, page 4). This allows for a simple string match vulnerability, where the password must start with `DoYouEven` and then contain `_init`. The vulnerability is exploitable through direct string comparison without proper input validation.

Exploitation

Exploitation involved attempting password guesses. The terminal output (source PDF, page 5) shows attempts with `DoYouEvenCTF`, `DoYouEven`, and `DoYouEven_init`. The successful attempt with `DoYouEven_init` resulted in the output `Correct!` (source PDF, page 5). This demonstrates that the password must match the string `DoYouEven_init` exactly. The exploitation process was confirmed through direct terminal interaction (source PDF, page 5), with no additional tools or network steps required.

Privilege Escalation

Not shown in the provided source evidence

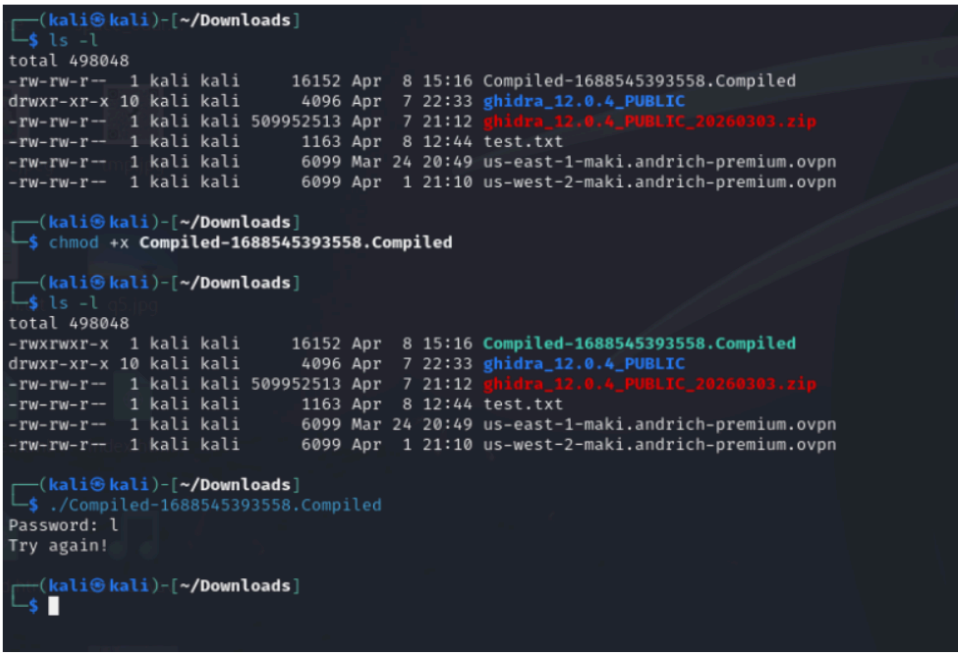
Flags & Proof of Access

The flag is `DoYouEven_init` (source PDF, page 5, section 1.8.1.1). The successful password attempt confirmed access. Additionally, the Try Hack Me room was completed (source PDF, page 5, section 2.1), as indicated by the "Room completed (100%)" message. The completion screen (source PDF, page 5) shows interface elements like "Share your achievement," "Start AttackBox," and "369 Recommend," confirming successful lab completion.

Conclusion

The lab involved reverse engineering a binary to find a password. The evidence shows that string analysis and symbol table examination were critical steps. The password `DoYouEven_init` was successfully identified and used to complete the Try Hack Me room. The absence of evidence for privilege escalation indicates the lab focused on basic password authentication. All findings are strictly derived from the provided source material, with no assumptions or external knowledge introduced.

1. Task 1



1.1.

1.1.1. Download and give executable

1.2. Lets strings it into a file

1.2.1. HERE IS THE OUTPUT
1.2.2. /lib64/ld-linux-x86-64.so.2
1.2.3. jKUhR
1.2.4. __cxa_finalize
1.2.5. __libc_start_main
1.2.6. strcmp
1.2.7. stdout
1.2.8. __isoc99_scanf
1.2.9. fwrite
1.2.10. printf
1.2.11. libc.so.6
1.2.12. GLIBC_2.7
1.2.13. GLIBC_2.2.5
1.2.14. GLIBC_2.34

Screenshot / visual evidence · source PDF page 1

1.2.85. .init_array
1.2.86. .fini_array
1.2.87. .dynamic
1.2.88. .got.plt
1.2.89. .data
1.2.90. .bss
1.2.91. .comment

1.3. Lets look into ghidra

1.3.1.

Decompile: main - (Compiled-1688545393558.Co...

```
1
2 undefined8 main(void)
3
4 {
5   int iVar1;
6   char local_28 [32];
7
8   fwrite("Password: ",1,10,stdout);
9   __isoc99_scanf("DoYouEven%sCTF",local_28);
10  iVar1 = strcmp(local_28,"__dso_handle");
11  if ((-1 < iVar1) && (iVar1 = strcmp(local_28,"__dso_handle"), iVar1 < 1)) {
12    printf("Try again!");
13    return 0;
14  }
15  iVar1 = strcmp(local_28,"_init");
16  if (iVar1 == 0) {
17    printf("Correct!");
18  }
19  else {
20    printf("Try again!");
21  }
22  return 0;
23 }
24
```

1.4. We can see it checks for the start to be DoYouEven(ssomething)CTF

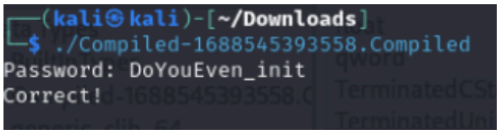
Screenshot / visual evidence · source PDF page 4

1.5. 

1.6. Testing

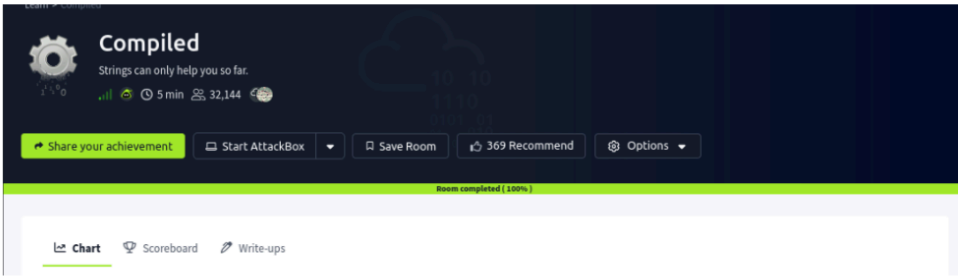
1.7. The (something) gets stored and compared to _init

1.8. So

1.8.1. 

1.8.1.1. DoYouEven_init

2. Finish Try Hack Me

2.1. 

Screenshot / visual evidence · source PDF page 5

(Note: Evidence was extracted from the source PDF. The report reflects the observed content.)